

Performing a Vulnerability Assessment (4e)

Fundamentals of Information Systems Security, Fourth Edition - Lab 02

Student:

Allen Chackalackal

Email:

allenalu02@gmail.com

Time on Task:

9 hours, 7 minutes

Progress:

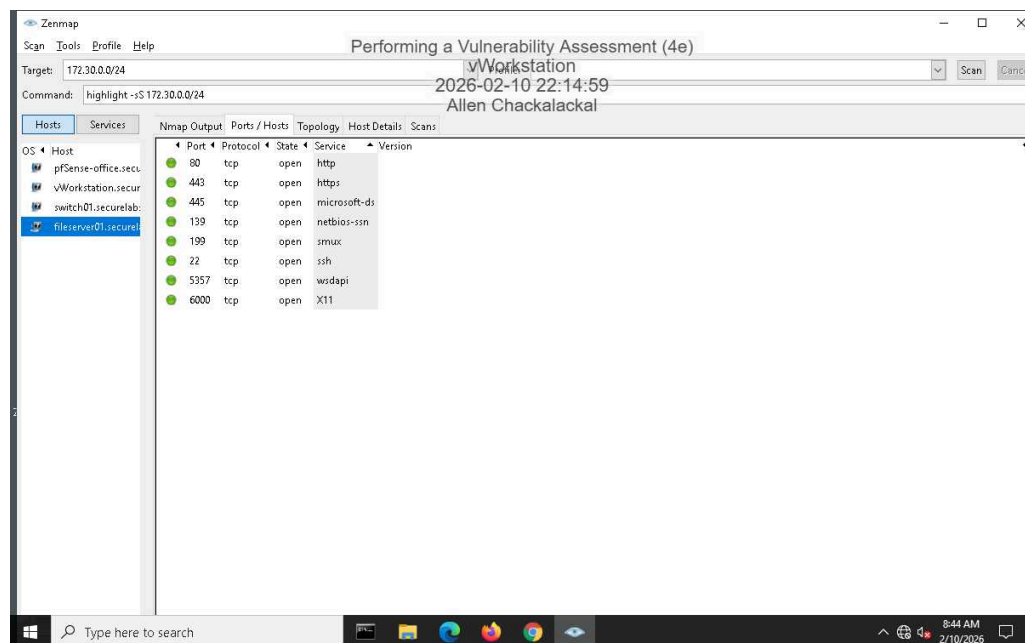
100%

Report Generated: Sunday, February 15, 2026 at 2:53 PM

Section 1: Hands-On Demonstration

Part 1: Scan the Network with Zenmap

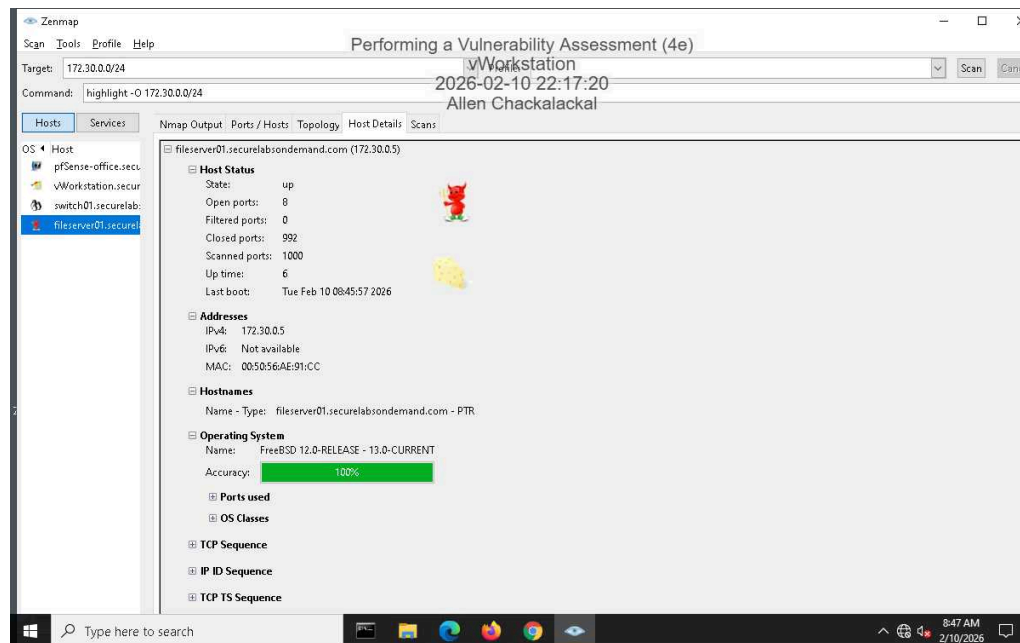
9. Make a screen capture showing the contents of the **Ports/Hosts** tab from the **SYN** scan for **fileserver01.securelabsondemand.com**.



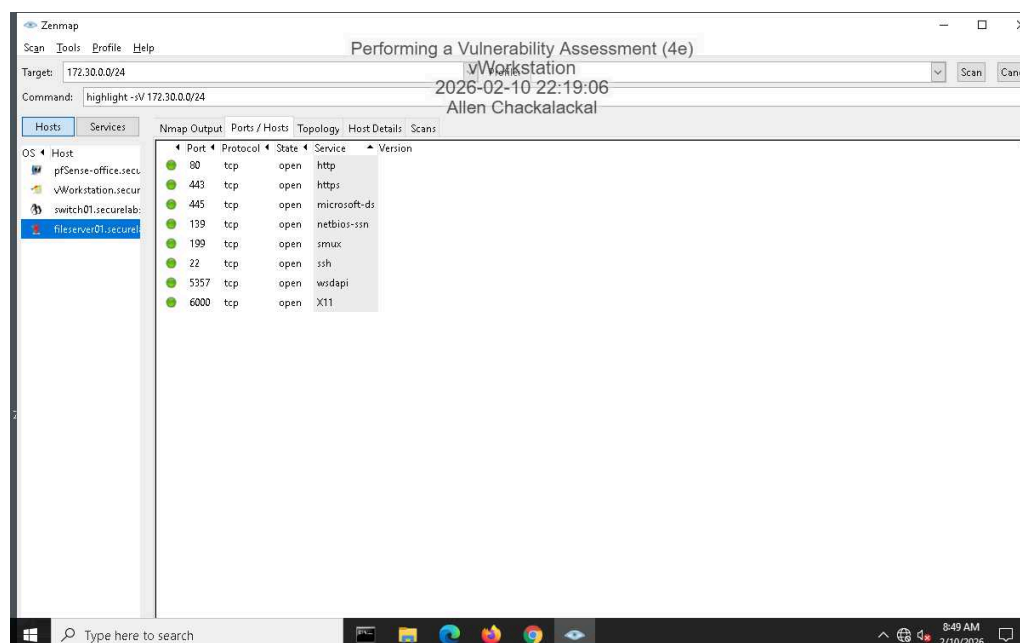
Performing a Vulnerability Assessment (4e)

Fundamentals of Information Systems Security, Fourth Edition - Lab 02

15. Make a screen capture showing the contents of the **Host Details** tab from the OS scan for **fileserver01.securelabsondemand.com**.

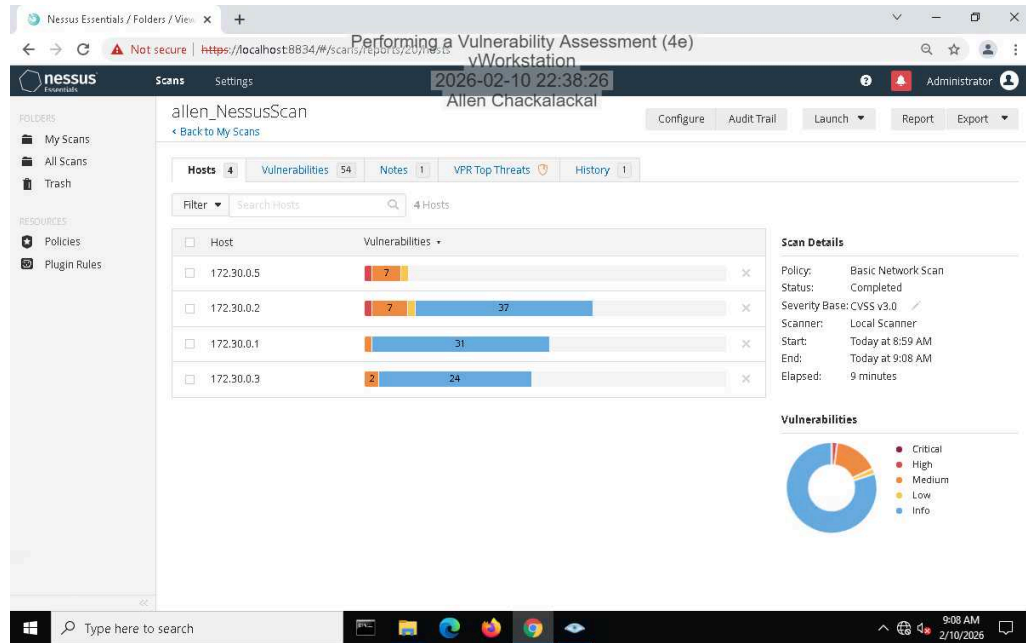


19. Make a screen capture showing the details in the **Ports/Hosts** tab from the Service scan for **fileserver01.securelabsondemand.com**.



Part 2: Conduct a Vulnerability Scan with Nessus

14. Make a screen capture showing the Nessus report summary.



Part 3: Evaluate Your Findings

11. **Summarize** the vulnerability you selected, including the CVSS risk score, and **recommend** a mitigation strategy.

The scan detected that the host 172.30.0.2 supports TLS 1.0, which is an outdated and deprecated cryptographic protocol. TLS 1.0 is vulnerable to several known attacks such as BEAST and other cryptographic weaknesses. Modern security standards (PCI DSS, NIST) no longer consider TLS 1.0 secure. If TLS 1.0 remains enabled:

Attackers may exploit cryptographic weaknesses

Sensitive data may be exposed during transmission

The system may fail compliance audits (PCI, ISO, etc.)

Increased risk of man-in-the-middle (MITM) attacks

Although not immediately critical, it weakens overall transport security.

CVSS v3.0 Score: 6.5 (Medium Severity) Recommended Mitigation Strategy

Disable TLS 1.0 and TLS 1.1 on the server.

Enable only secure protocols:

TLS 1.2

TLS 1.3 (preferred)

Update server configuration:

For Apache ? modify ssl.conf

For Nginx ? update ssl_protocols

For Windows Server ? disable via registry or IIS Crypto

Restart the service after changes.

Re-scan the system to confirm remediation.

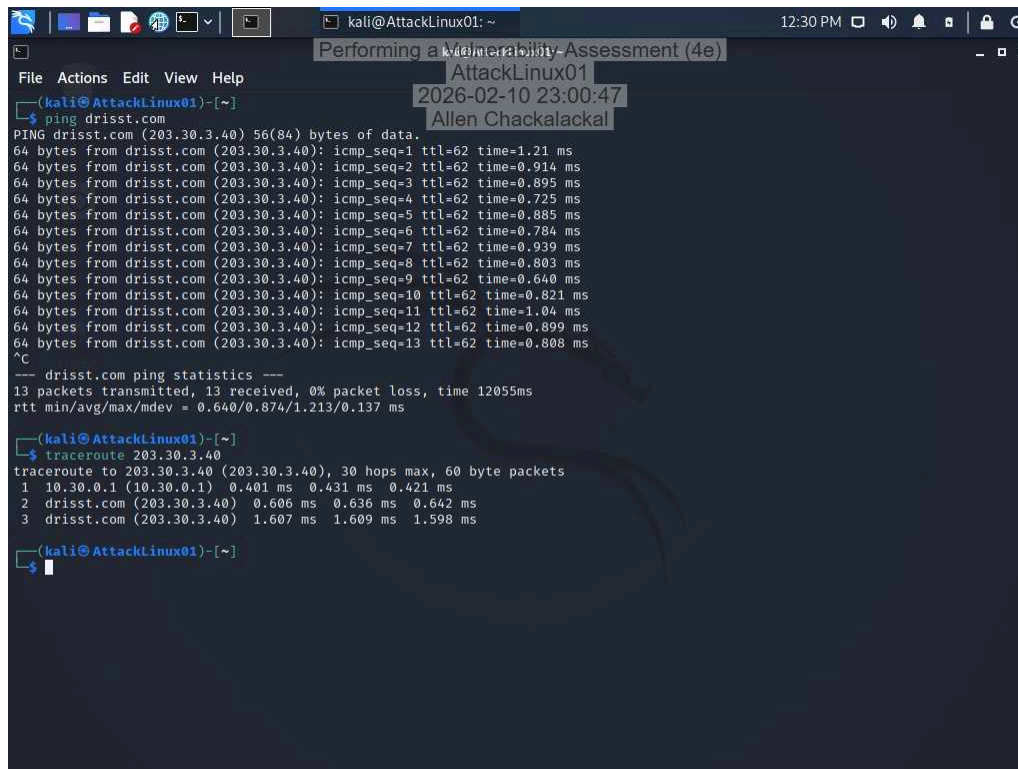
Conclusion

The system is currently supporting deprecated TLS 1.0 protocol, resulting in a CVSS score of 6.5 (Medium). Disabling legacy protocols and enforcing TLS 1.2/1.3 will significantly improve transport layer security and reduce exposure to cryptographic attacks.

Section 2: Applied Learning

Part 1: Scan the Network with Nmap

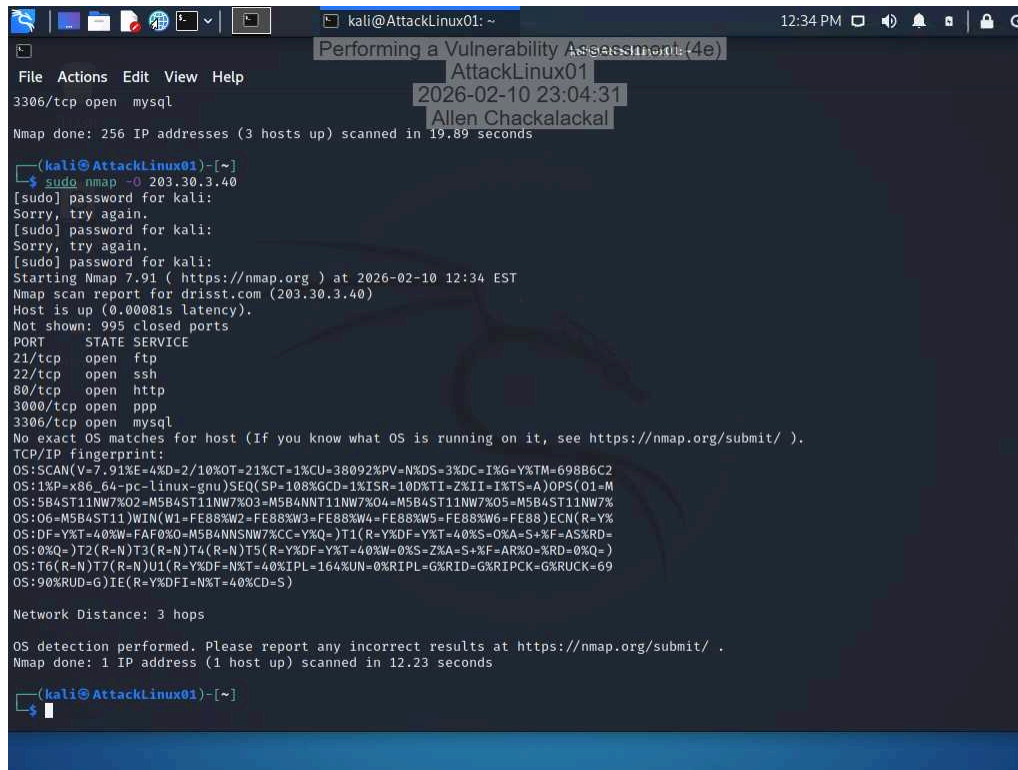
6. Make a screen capture showing the results of the traceroute command.



The screenshot shows a Kali Linux terminal window with the following content:

```
kali@AttackLinux01: ~  
Performing a Vulnerability Assessment (4e)  
AttackLinux01  
2026-02-10 23:00:47  
Allen Chackalackal  
File Actions Edit View Help  
kali@AttackLinux01:~]  
$ ping drisst.com  
PING drisst.com (203.30.3.40) 56(84) bytes of data:  
64 bytes from drisst.com (203.30.3.40): icmp_seq=1 ttl=62 time=1.21 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=2 ttl=62 time=0.914 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=3 ttl=62 time=0.895 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=4 ttl=62 time=0.725 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=5 ttl=62 time=0.885 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=6 ttl=62 time=0.784 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=7 ttl=62 time=0.939 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=8 ttl=62 time=0.803 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=9 ttl=62 time=0.640 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=10 ttl=62 time=0.821 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=11 ttl=62 time=1.04 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=12 ttl=62 time=0.899 ms  
64 bytes from drisst.com (203.30.3.40): icmp_seq=13 ttl=62 time=0.808 ms  
^C  
--- drisst.com ping statistics ---  
13 packets transmitted, 13 received, 0% packet loss, time 12055ms  
rtt min/avg/max/mdev = 0.640/0.874/1.213/0.137 ms  
kali@AttackLinux01:~]  
$ traceroute 203.30.3.40  
traceroute to 203.30.3.40 (203.30.3.40), 30 hops max, 60 byte packets  
1 10.30.0.1 (10.30.0.1) 0.401 ms 0.431 ms 0.421 ms  
2 drisst.com (203.30.3.40) 0.606 ms 0.636 ms 0.642 ms  
3 drisst.com (203.30.3.40) 1.607 ms 1.609 ms 1.598 ms  
kali@AttackLinux01:~]  
$
```

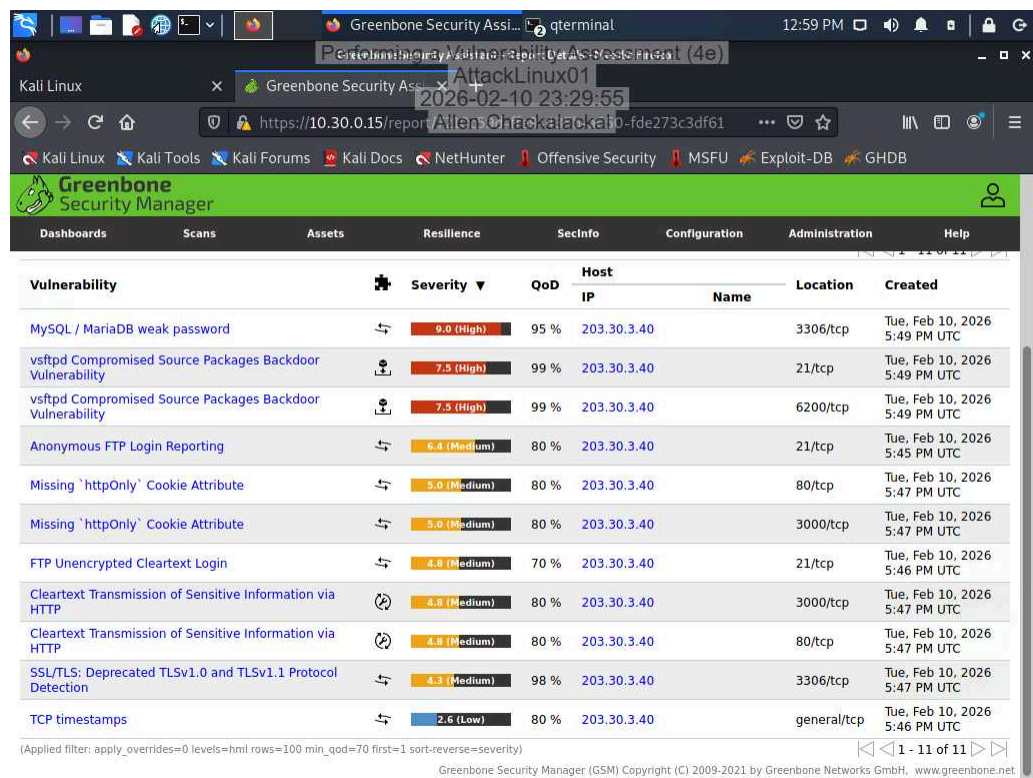
10. Make a screen capture showing the results of the Nmap scan with OS detection activated.



```
kali@AttackLinux01: ~  
File Actions Edit View Help  
3306/tcp open  mysql  
Nmap done: 256 IP addresses (3 hosts up) scanned in 19.89 seconds  
  
(kali@AttackLinux01)-[~]  
$ sudo nmap -O 203.30.3.40  
[sudo] password for kali:  
Sorry, try again.  
[sudo] password for kali:  
Sorry, try again.  
[sudo] password for kali:  
Starting Nmap 7.91 ( https://nmap.org ) at 2026-02-10 12:34 EST  
Nmap scan report for drisst.com (203.30.3.40)  
Host is up (0.00081s latency).  
Not shown: 995 closed ports  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
80/tcp    open  http  
3000/tcp  open  ppp  
3306/tcp  open  mysql  
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/).  
TCP/IP fingerprint:  
OS:SCAN(V-7.91%E=4%D-2/10%OT-21%CT-1%CU-38092%PV-NXDS-3%DC-I%G-Y%TM-698B6C2  
OS:1XP-x86_64-pe-linux-gnu)SEQ(SP-108%GCD-1%ISR-10D%TI-Z%TI-1%TS-A)OPS(O1-M  
OS:5B4ST11NW7%O2-M5B4ST11NW7%O3-M5B4NNT11NW7%O4-M5B4ST11NW7%O5-M5B4ST11NW7%  
OS:O6-M5B4ST11)WIN(W1-FE88%W2-FE88%W3-FE88%W4-FE88%W5-FE88%W6-FE88)ECN(R-Y%  
OS:DF-Y%T-40%W-FAF0%O-M5B4NNSNW7%CC-Y%Q-)TI(R-Y%DF-Y%T-40%W-0%S-Z%A-S+%F-AR%O-%RD-0%Q-)  
OS:0%Q-)T2(R-N)T3(R-N)T4(R-N)T5(R-Y%DF-Y%T-40%W-0%S-Z%A-S+%F-AR%O-%RD-0%Q-)  
OS:T6(R-N)T7(R-N)U1(R-Y%DF-N%T-40%IPL-164%UN-0%RIPL-G%RID-G%RIPCK-G%RUCK-69  
OS:90%RUD=G)IE(R-Y%DFI=N%T=40%CD=S)  
  
Network Distance: 3 hops  
  
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 12.23 seconds  
  
(kali@AttackLinux01)-[~]  
$
```

Part 2: Conduct a Vulnerability Scan with OpenVAS

13. Make a screen capture showing the detailed OpenVAS scan results.



Part 3: Prepare a Penetration Test Report

Target

Insert the target here.

drisst.com web server

Completed by

Insert your name here.

Allen Chackalackal

On

Insert current date here.

10/02/2026

Purpose

Identify the purpose of the penetration test.

The purpose of this penetration test was to identify high-severity security vulnerabilities affecting the drisst.com web server. The test was conducted to evaluate the security posture of the system, identify weaknesses that could be exploited by a malicious attacker, and provide remediation guidance to reduce risk and improve overall system security.

Scope

Identify the scope of the penetration test.

The scope of this penetration test was limited to a non-intrusive vulnerability assessment of the drisst.com web server. Testing activities included network discovery and vulnerability scanning using Nmap and OpenVAS. No exploitation, denial-of-service attacks, or destructive testing techniques were performed. The assessment focused only on identifying vulnerabilities and did not include attempting to gain unauthorized access or modify system data.

Summary of Findings

Identify and summarize each of the three high-severity vulnerabilities identified during your penetration test. For each vulnerability, identify the severity, describe the issue, and recommend a remediation.

Vulnerability 1: MySQL / MariaDB Weak Password

Severity: High (CVSS 9.0)

Description: The OpenVAS scan identified that the MySQL/MariaDB database service allows authentication using weak credentials. This indicates poor password policy enforcement and exposes the database service to brute-force or credential guessing attacks.

Vulnerability 2: vsftpd Compromised Source Packages Backdoor Vulnerability

Severity: High (CVSS 7.5) CVE: CVE-2011-2523

Description: The scan detected a vulnerable version of vsftpd (Very Secure FTP Daemon) that contains a malicious backdoor. This backdoor was introduced in a compromised version of the software and allows remote attackers to execute arbitrary commands.

Vulnerability 3: vsftpd Backdoor Service Running on Port 6200

Severity: High

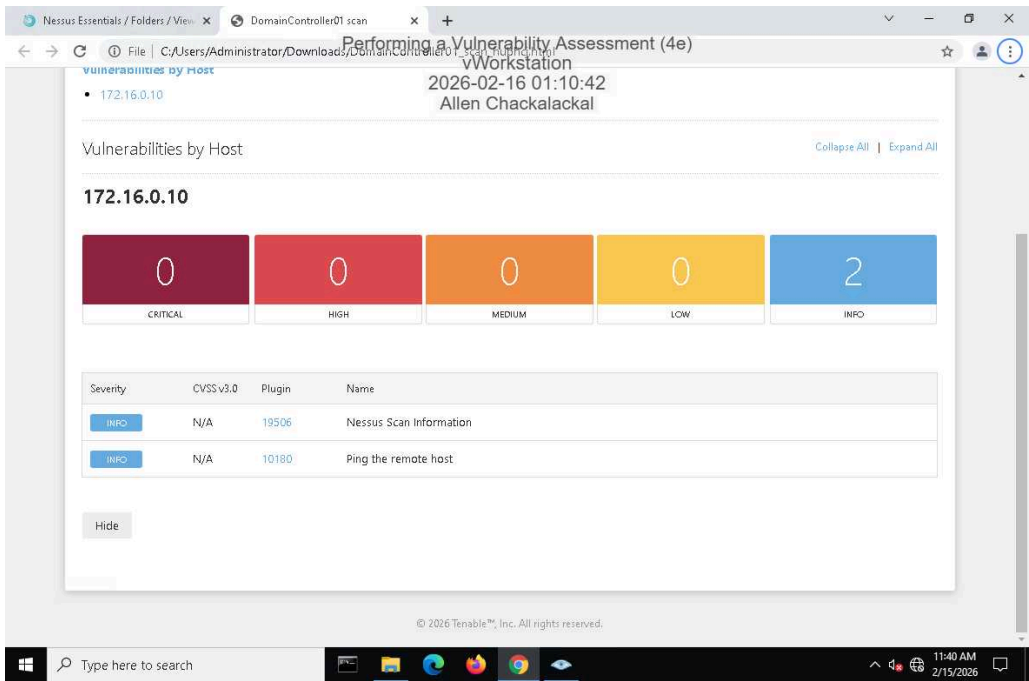
Description: The backdoor associated with the compromised vsftpd service opens a shell listener on TCP port 6200. This allows unauthorized remote access without authentication.

Conclusion

Identify your key findings.

The penetration test identified three high-severity vulnerabilities affecting the target system, including weak database authentication and a compromised FTP service containing a known backdoor (CVE-2011-2523). These issues present a significant risk, as they could allow an attacker to gain unauthorized access, execute arbitrary commands, and potentially achieve full system compromise. Although no active exploitation was performed during this assessment, the presence of these vulnerabilities indicates that the system is highly exposed to real-world attacks. Immediate remediation is strongly recommended, including removal of the compromised vsftpd service, enforcement of strong authentication controls, and implementation of proper security hardening measures. Addressing these findings promptly will significantly reduce the attack surface and improve the overall security posture of the system.

Make a screen capture showing the Nessus report summary for the domain controller.



Part 3: Prepare a Penetration Test Report

Target

Insert the target here.

Domain Controller 172.16.0.30

Completed by

Insert your name here.

Allen Chackalackal

On

Insert current date here.

15/2/2025

Purpose

Identify the purpose of the penetration test.

The purpose of this penetration test was to evaluate the security posture of the Domain Controller (172.16.0.10) within the Secure Labs on Demand internal network. This assessment was conducted using Nessus to identify potential vulnerabilities, misconfigurations, or security weaknesses that could be exploited by an attacker. The objective was to determine whether the Domain Controller is exposed to high-risk vulnerabilities and to provide recommendations to strengthen its overall security.

Scope

Identify the scope of the penetration test.

The scope of this assessment was limited to a non-credentialed vulnerability scan of the Domain Controller (172.16.0.10) using Nessus Basic Network Scan. The test focused on identifying externally visible vulnerabilities, open services, and potential security misconfigurations accessible from the internal lab network. No exploitation activities were performed, and no credentialed scanning or intrusive testing was conducted. The assessment was restricted strictly to the specified target system and did not include any other hosts within the network.

Summary of Findings

Identify and summarize each vulnerability identified during your penetration test. For each vulnerability, identify the severity, describe the issue, and recommend a remediation.

Identified Informational Findings:

Nessus Scan Information

Provides metadata about the scan configuration and execution.

No security risk associated.

Ping the Remote Host

Confirms the host is reachable over the network.

No vulnerability detected.

Analysis:

No exploitable vulnerabilities were identified during this non-credentialed vulnerability scan. The absence of high or critical findings suggests that the Domain Controller is properly patched and hardened against common remote attacks.

Conclusion

Identify your key findings.

The vulnerability assessment of the Domain Controller (172.16.0.10) was conducted using a Nessus Basic Network Scan to evaluate its exposure to security weaknesses. The scan did not identify any critical, high, medium, or low severity vulnerabilities. Only informational findings were detected, indicating that the system is reachable and properly responding to network probes. Based on the results of this assessment, the Domain Controller demonstrates a strong security posture against the tested attack vectors within the scope of this non-credentialed scan. It is recommended that regular vulnerability assessments and periodic credentialed scans be performed to ensure continued protection against emerging threats and internal misconfigurations.